BÁO CÁO LỖI (DEFECT / BUG REPORT) - DỰ ÁN ESHOP SUT

Bài tập Tuần 02 (HW02-AI) - Domain Testing & Boundary Value Analysis (BVA)

- **Môn học:** Software Testing (CSC13003) - FIT@HCMUS
- **Tiêu chuẩn áp dụng:** Slide S08 — Bug Report 10 Essentials & Guru99 Defect Life Cycle
- **Người thực hiện:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
- **Ngày lập báo cáo:** 19/10/2026

---

1. Bảng Tổng Hợp Danh Mục Lỗi (Defect Summary Table)

Bug ID	Chức năng (Function)	Tóm tắt lỗi (Problem Summary)	Defect Type	Priority	Severity	Status
BUG-FR01-01	FR-01: Đăng ký tài khoản (UI)	Regex cấm ký tự `@` và bắt buộc khoảng trắng; chặn mật khẩu hợp lệ	Coding logic / Regex	**Immediate**	**Serious**	Open
BUG-FR01-02	FR-01: Đăng ký tài khoản (UI)	Giao diện form thiếu hoàn toàn trường "Xác nhận mật khẩu"	Feature missing	**High**	**Serious**	Open
BUG-FR01-03	FR-01: Đăng ký tài khoản (UI)	Input Email dùng `type="text"`, thiếu validation định dạng RFC	User Interface	**Medium**	**Medium**	Open
BUG-FR01-04	FR-01: Đăng ký tài khoản (UI)	Nút "Đăng ký" dùng màu đỏ (`bg-red-500`) vi phạm quy chuẩn thiết kế UI	User Interface	**Low**	**Cosmetic**	Open
BUG-FR01-05	FR-01: Đăng ký tài khoản (API)	Backend lưu mật khẩu plaintext, bảng `users` thiếu UNIQUE cho email	Security / Database	**Immediate**	**Fatal**	Open
BUG-FR01-06	FR-01: Đăng ký tài khoản (Full)	Thiếu kiểm tra tập ký tự Họ Tên & Email (chấp nhận số, XSS, cú pháp `_@)`)	Robustness / Security	**High**	**Serious**	Open

---

2. Hồ Sơ Chi Tiết Từng Lỗi (Theo 10 Thành Phần Chuẩn Slide S08)

BUG-FR01-01: Regex mật khẩu bắt buộc khoảng trắng và cấm ký tự đặc biệt

1. **Bug ID:** `BUG-FR01-01`
2. **Function name:** `FR-01: Đăng ký tài khoản (Web Client)`
3. **Problem summary:** `Verify Registration with Valid Password: Valid password 'ValidPass@123' is rejected with 'Mật khẩu quá yếu!' instead of being accepted.`
4. **How to reproduce the defect:**
   - **Environment:** Windows 11, Google Chrome 120+, Frontend Web port 5173, React 18.
   - **Steps to Reproduce:**
     1. Mở trình duyệt, truy cập `http://localhost:5173/register`.
     2. Nhập Họ Tên: `"Nguyen Van A"`, Email: `"validuser@gmail.com"`.
     3. Nhập Mật khẩu: `"ValidPass@123"`.
     4. Nhấp nút "Đăng ký".
   - **Expected Behavior:** Hệ thống chấp nhận mật khẩu hợp lệ thỏa mãn đầy đủ tiêu chuẩn đặc tả FR-01 (≥ 8 ký tự, có chữ hoa, chữ thường, số, và ký tự `@`), tiến hành gửi request đăng ký.
   - **Actual Behavior:** Trình duyệt hiển thị popup thông báo lỗi *"Mật khẩu quá yếu!"*; form bị chặn submit.
   - **Root Cause & Code Reference:** Tại file `frontend-web/src/pages/Register.jsx` dòng 15:

     ```
     const flawedStrongPasswordRegex = /^(?=.*[a-z])(?=.*[A-Z])(?=.*\d)(?=.*\s)[A-Za-z\d\s]{8,}$/;
     ```

     Biểu thức chính quy này chứa nhóm `(?=.*\s)` bắt buộc phải có dấu cách, đồng thời tập ký tự `[A-Za-z\d\s]` cấm toàn bộ các ký tự đặc biệt hợp lệ `@$!%*?&`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 19/10/2026
7. **Assign to:** Frontend Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)` — Phải sửa ngay trong 01 ngày vì làm tê liệt luồng đăng ký của người dùng bình thường.
10. **Severity:** `Serious` — Ảnh hưởng nghiêm trọng đến tính năng chính của hệ thống.

BUG-FR01-02: Giao diện form thiếu hoàn toàn trường "Xác nhận mật khẩu"

1. **Bug ID:** `BUG-FR01-02`
2. **Function name:** `FR-01: Đăng ký tài khoản (Web Client)`
3. **Problem summary:** `Validate Confirm Password field: Registration form completely lacks Confirm Password input field instead of providing confirmation check.`
4. **How to reproduce the defect:**
   - **Environment:** Web Client port 5173.
   - **Steps to Reproduce:**
     1. Mở trang `http://localhost:5173/register`.
     2. Quan sát toàn bộ giao diện form đăng ký.
   - **Expected Behavior:** Form phải có 4 trường bắt buộc theo đặc tả FR-01: Họ Tên, Email, Mật khẩu, và Xác nhận mật khẩu; hệ thống phải đối chiếu hai trường mật khẩu trùng khớp nhau trước khi submit.

- **Actual Behavior:** Giao diện chỉ có 3 ô input: Họ tên (`name`), Email (`email`), Mật khẩu (`password`). Hoàn toàn không có ô `confirmPassword`.
- **Root Cause & Code Reference:** Trong `frontend-web/src/pages/Register.jsx`, state `formData` chỉ khởi tạo `{ name: '', email: '', password: '' }` và không render thẻ input cho trường xác nhận.

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 19/10/2026
7. **Assign to:** Frontend Developer
8. **Status:** `Open / New`
9. **Priority:** `High` — Phải sửa trong 02-04 ngày vì vi phạm đặc tả chức năng cốt lõi.
10. **Severity:** `Serious` — Bỏ mất chốt chặn an toàn bảo vệ người dùng tránh gõ nhầm mật khẩu.

BUG-FR01-03: Trường Email không dùng `type="email"` và thiếu validation format

1. **Bug ID:** `BUG-FR01-03`
2. **Function name:** `FR-01: Đăng ký tài khoản (Web Client)`
3. **Problem summary:** `Test Email Input Type & Syntax: Email input uses type='text' instead of type='email', allowing invalid formats like 'invalidemail.com' to submit.`
4. **How to reproduce the defect:**
   - **Environment:** Web Client port 5173.
   - **Steps to Reproduce:**
     1. Mở `/register`.
     2. Nhập Họ Tên: `"Nguyen Van A"`, Email: `"invalidemail.com"` (thiếu `@`), Mật khẩu workaround: `"ValidPass 123"`.
     3. Nhấp "Đăng ký".
   - **Expected Behavior:** Trình duyệt kích hoạt HTML5 email validation hoặc code ném lỗi yêu cầu email phải có định dạng hợp lệ.
   - **Actual Behavior:** Form submit thành công, gửi thẳng chuỗi `invalidemail.com` lên backend và backend lưu vào CSDL.
   - **Root Cause & Code Reference:** Tại file `frontend-web/src/pages/Register.jsx` dòng 48:

     ```
     <input type="text" name="email" required ... />
     ```

     Input bị gán sai kiểu `type="text"` và không có biểu thức chính quy kiểm tra định dạng email theo RFC 5322.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 19/10/2026
7. **Assign to:** Frontend Developer
8. **Status:** `Open / New`
9. **Priority:** `Medium` — Sửa trong 05-08 ngày.
10. **Severity:** `Medium` — Sai lệch quy chuẩn form HTML5 và tiêu chuẩn nghiệp vụ FR-22.

BUG-FR01-04: Nút "Đăng ký" sai màu quy chuẩn thiết kế UI

1. **Bug ID:** `BUG-FR01-04`
2. **Function name:** `FR-01: Giao diện Đăng ký (Web Client UI)`
3. **Problem summary:** `Check Register Button Color: Submit button displays red color (bg-red-500) instead of standard design blue color.`
4. **How to reproduce the defect:**
   - **Environment:** Web Client port 5173.
   - **Steps to Reproduce:** Truy cập `/register` và quan sát nút "Đăng ký".
   - **Expected Behavior:** Nút gửi form chính của hệ thống phải có màu xanh dương theo quy chuẩn thiết kế FR-21.
   - **Actual Behavior:** Nút hiển thị màu đỏ rực (`bg-red-500` - màu thường dành cho hành động hủy hoặc nguy hiểm).
   - **Root Cause & Code Reference:** Tại file `frontend-web/src/pages/Register.jsx` dòng 72: class Tailwind gán `bg-red-500 hover:bg-red-600`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 19/10/2026
7. **Assign to:** Frontend Developer
8. **Status:** `Open / New`
9. **Priority:** `Low` — Sửa trong đợt refactor giao diện tiếp theo.
10. **Severity:** `Cosmetic` — Lỗi thẩm mỹ, không làm hỏng tính năng nghiệp vụ.

BUG-FR01-05: Backend không validate dữ liệu, không check trùng email, lưu mật khẩu plaintext

1. **Bug ID:** `BUG-FR01-05`
2. **Function name:** `FR-01: API Đăng ký tài khoản (Backend Server)`
3. **Problem summary:** `Validate Register API Security: Backend allows duplicate emails and stores unhashed plaintext passwords instead of rejecting with HTTP 409 and hashing with bcrypt.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API port 3000, SQLite 3 database.
   - **Steps to Reproduce:**
     1. Gửi request `POST /api/register` với body: `{"name": "Nguyen Van A", "email": "test@eshop.com", "password": "ValidPass 123"}` (email đã có trong database).
     2. Mở file CSDL SQLite và truy vấn `SELECT * FROM users WHERE email = 'test@eshop.com'`.
   - **Expected Behavior:** Backend phải kiểm tra sự tồn tại của email, trả về mã lỗi HTTP 409 Conflict. Nếu email mới, mật khẩu phải được băm bảo mật bằng thuật toán an toàn như `bcrypt` trước khi lưu (tiêu chuẩn SEC-01).
   - **Actual Behavior:** Backend trả về HTTP 200/201 đăng ký thành công. Truy vấn CSDL thấy xuất hiện 2 dòng cùng email `test@eshop.com`, và cột `password` chứa chuỗi ký tự bản rõ `"ValidPass 123"` mà không hề được băm.
   - **Root Cause & Code Reference:**
     - Trong `backend/database.js`: Cột `email TEXT` không có ràng buộc `UNIQUE`.
     - Trong `backend/server.js` tuyến `POST /api/register`: Gọi lệnh `INSERT INTO users (name, email, password) VALUES (?, ?, ?)` trực tiếp mà không kiểm tra trùng lặp hay gọi `bcrypt.hash()`.

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 19/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)` — Phải vá lỗi ngay trong 01 ngày.
10. **Severity:** `Fatal` — Lỗ hổng bảo mật nghiêm trọng làm lộ toàn bộ mật khẩu người dùng khi CSDL bị truy cập và làm hỏng toàn vẹn dữ liệu.

BUG-FR01-06: Hệ thống thiếu kiểm tra tập ký tự Họ Tên & Email (nhận số, script XSS, cú pháp phi lý `_@)`)

1. **Bug ID:** `BUG-FR01-06`
2. **Function name:** `FR-01: Input Sanitization & Robustness (Full Stack)`
3. **Problem summary:** `Validate Character Sets & Sanitization: System accepts numeric names, malicious XSS script payloads, and malformed email '_@)' instead of rejecting invalid character sets.`
4. **How to reproduce the defect:**
   - **Environment:** Web Client port 5173 & Backend API port 3000.
   - **Steps to Reproduce:**
     1. Mở `/register`.
     2. Nhập Họ Tên: `"<script>alert(1)</script>"`, Email: `"_@)"`, Mật khẩu workaround: `"ValidPass 123"`.
     3. Bấm Đăng ký.
   - **Expected Behavior:** Hệ thống phát hiện họ tên chứa ký tự đặc biệt nguy hiểm và cấu trúc email không có tên miền hợp lệ (FQDN/TLD), từ chối submit và thông báo lỗi.
   - **Actual Behavior:** Cả Frontend và Backend đều cho qua 100%, tài khoản được tạo thành công với chuỗi script độc hại và địa chỉ email phi lý `_@)` trong CSDL SQLite.
   - **Root Cause:** SUT thiếu hoàn toàn tầng Sanitize và thư viện kiểm tra tập ký tự (như `validator.isAlpha()` cho Họ Tên và `validator.isEmail()` cho Email).
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 19/10/2026
7. **Assign to:** Fullstack Developer
8. **Status:** `Open / New`
9. **Priority:** `High` — Sửa trong 02-04 ngày.
10. **Severity:** `Serious` — Gây nguy cơ tấn công Stored XSS khi trang Admin hiển thị danh sách người dùng và nguy cơ sập tiến trình Backend khi gửi mail tới domain không hợp lệ.

PHẦN 2: DANH SÁCH LỖI PHÁT HIỆN TẠI FEATURE B — FR-09: ÁP DỤNG MÃ GIẢM GIÁ (COUPON)

BUG-FR09-01: Sai công thức toán học khi tính giảm giá theo phần trăm (SAVE10)

1. **Bug ID:** `BUG-FR09-01`
2. **Function name:** `FR-09: Tính toán giảm giá theo phần trăm (Backend API)`

3. **Problem summary:** `Calculate Percentage Discount: Backend multiplies total by negative factor (1 - discount_value) instead of (total * discount_value / 100), increasing order total 10-fold.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `http://localhost:3000/api/apply-coupon`, Node.js Express.
   - **Steps to Reproduce:**
     1. Gửi request `POST /api/apply-coupon` với body: `{"code": "SAVE10", "total_amount": 400000, "user_id": 2}`.
     2. Quan sát kết quả JSON trả về.
   - **Expected Behavior:** Giảm 10% của 400,000 ₫ là 40,000 ₫; `discount_amount: 40000`, `final_amount: 360000`.
   - **Actual Behavior:** Hệ thống trả về `discount_amount: -3600000`, `final_amount: 4000000` (khách hàng bị đội giá gấp 10 lần).
   - **Root Cause & Code Reference:** Tại file `backend/server.js` dòng 406:

     ```
     discount_amount = Math.floor(total_amount * (1 - coupon.discount_value));
     ```

     Với `coupon.discount_value = 10`, `(1 - 10) = -9`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)` — Tính toán sai tiền của khách hàng, đe dọa trực tiếp hoạt động kinh doanh.
10. **Severity:** `Fatal` — Gây thiệt hại tài chính nghiêm trọng và tính sai giá trị thanh toán.

BUG-FR09-02: Sai toán tử so sánh ngưỡng tối thiểu (sử dụng '>' thay vì '>=')

1. **Bug ID:** `BUG-FR09-02`
2. **Function name:** `FR-09: Kiểm tra ngưỡng giá trị tối thiểu (Backend API)`
3. **Problem summary:** `Validate Minimum Order Amount: Backend uses strict inequality '>' instead of '>=', falsely rejecting orders exactly equal to min_order_amount.`
4. **How to reproduce the defect:**
   - **Environment:** Web Client `:5173` & Backend `:3000`.
   - **Steps to Reproduce:**
     1. Nhập đơn hàng có tổng tiền đúng `500,000 ₫`.
     2. Nhập mã `'BIGBUY'` (có `min_order_amount = 500,000 ₫`).
     3. Nhấp "Áp dụng".
   - **Expected Behavior:** Hệ thống chấp nhận mã hợp lệ vì $500,000 \geq 500,000$ (thỏa mãn điều kiện C3).
   - **Actual Behavior:** Hệ thống từ chối với HTTP 400: "*Đơn hàng chưa đủ giá trị tối thiểu 500,000 ₫ để áp dụng mã này*".
   - **Root Cause & Code Reference:** Tại `backend/server.js` dòng 385:

```
if (total_amount > coupon.min_order_amount) { // Thiếu dấu =
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `High`
10. **Severity:** `Serious` — Từ chối sai các khách hàng đạt đủ điều kiện khuyến mãi tối thiểu.

BUG-FR09-03: Endpoint áp dụng coupon không yêu cầu xác thực JWT (Vi phạm C4)

1. **Bug ID:** `BUG-FR09-03`
2. **Function name:** `FR-09: Xác thực người dùng khi áp coupon (Security / API)`
3. **Problem summary:** `Authenticate Coupon Application: POST /api/apply-coupon lacks authenticateToken middleware, violating C4 requirement.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Gửi request `POST /api/apply-coupon` với body `{"code": "BIGBUY", "total_amount": 600000}` mà không kèm header `Authorization: Bearer <token>`.
   - **Expected Behavior:** Backend trả về HTTP 401 Unauthorized yêu cầu đăng nhập theo quy định C4.
   - **Actual Behavior:** Backend trả về HTTP 200 thành công cho khách vãng lai.
   - **Root Cause:** Route `app.post("/api/apply-coupon", ...)` trong `server.js` thiếu middleware `authenticateToken`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `High`
10. **Severity:** `Serious` — Vi phạm ràng buộc bảo mật và quản lý khuyến mãi của hệ thống.

BUG-FR09-04: Backend nhận user_id từ request body gây nguy cơ ID Spoofing

1. **Bug ID:** `BUG-FR09-04`
2. **Function name:** `FR-09: Kiểm soát định danh người dùng (Security / API)`
3. **Problem summary:** `Authorize User Identity: Backend trusts client-provided user_id in body instead of extracting from verified JWT token, allowing quota bypass.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Tài khoản A (User ID 2) đã dùng hết lượt mã `BIGBUY`.
     2. Gửi request với body `{"code": "BIGBUY", "total_amount": 600000, "user_id": 999}`.

- **Expected Behavior:** Backend lấy `req.user.id` từ token, phát hiện đã hết lượt và từ chối.
- **Actual Behavior:** Backend truy vấn `user_id = 999`, không thấy lịch sử dùng và cho phép áp dụng thành công.
- **Root Cause:** `server.js:370` lấy `const { code, total_amount, user_id } = req.body;`.

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `High`
10. **Severity:** `Serious` — Lỗ hổng cho phép kẻ gian giả mạo ID người dùng khác để qua mặt hạn ngạch sử dụng coupon.

BUG-FR09-05: Giao diện Checkout cho phép người dùng tự do nhập và sửa tổng tiền thanh toán

1. **Bug ID:** `BUG-FR09-05`
2. **Function name:** `FR-08 / FR-09: Toàn vẹn dữ liệu đơn hàng (Web Client / Security)`
3. **Problem summary:** `Enforce Order Total Integrity: Checkout page exposes an editable input for total amount, allowing price tampering.`
4. **How to reproduce the defect:**
   - **Environment:** Web Client `http://localhost:5173/checkout`.
   - **Steps to Reproduce:**
     1. Mở trang Checkout.
     2. Tại ô "Tổng tiền thanh toán (VND)", gõ trực tiếp số tiền `600,000 ₫` (mặc dù giỏ hàng chỉ có món 50,000 ₫).
     3. Nhập mã `'BIGBUY'` và bấm Áp dụng.
   - **Expected Behavior:** Tổng tiền thanh toán là trường chỉ đọc (read-only), tự động tính từ giỏ hàng (theo đặc tả FR-08 dòng 105).
   - **Actual Behavior:** Input cho phép sửa tự do, người dùng có thể kích hoạt các mã giảm giá giá trị cao hoặc giảm giá tiền thanh toán tùy ý.
   - **Root Cause:** `frontend-web/src/pages/Checkout.jsx` dòng 93-103 render `<input type="number" value={editableTotal} onChange=... />`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Fullstack Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)`
10. **Severity:** `Fatal` — Lỗ hổng cho phép người mua gian lận tùy ý giá trị thanh toán của đơn hàng.

BUG-FR09-06: Ghi nhận lượt sử dụng coupon tách rời khỏi transaction thanh toán

1. **Bug ID:** `BUG-FR09-06`
2. **Function name:** `FR-09: Quản lý tính nguyên tử của giao dịch (Architecture / Fullstack)`
3. **Problem summary:** `Persist Coupon Usage: Frontend executes separate uncoordinated call to /api/coupon-usage, risking unrecorded single-use coupons.`

4. **How to reproduce the defect:**
    - **Environment:** Web Client `:5173` & Backend `:3000`.
    - **Steps to Reproduce:**
        1. Áp dụng mã `BIGBUY` (mã dùng 1 lần) và tiến hành đặt hàng.
        2. Dùng DevTools chặn request thứ hai gửi tới `/api/coupon-usage` sau khi `/api/checkout` đã thành công.
    - **Expected Behavior:** Đơn hàng và việc ghi nhận trừ lượt dùng coupon phải nằm chung trong 1 transaction nguyên tử tại Backend.
    - **Actual Behavior:** Đơn hàng được tạo thành công nhưng bảng `coupon_usage` không có bản ghi nào, người dùng có thể tiếp tục dùng mã này cho các đơn hàng tiếp theo.
    - **Root Cause:** `Checkout.jsx` dòng 54-59 thực hiện 2 request HTTP độc lập thay vì backend xử lý trong cùng 1 transaction.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Fullstack Developer
8. **Status:** `Open / New`
9. **Priority:** `High`
10. **Severity:** `Serious` — Thiếu tính nguyên tử (Atomicity), gây rủi ro lạm dụng mã giảm giá nhiều lần.

PHẦN 3: DANH SÁCH LỖI PHÁT HIỆN TẠI FEATURE C — FR-15: QUẢN LÝ SẢN PHẨM (PRODUCT CRUD)

BUG-FR15-01: Tuyến API CRUD sản phẩm thiếu hoàn toàn xác thực JWT và phân quyền Admin (Broken Access Control)

1. **Bug ID:** `BUG-FR15-01`
2. **Function name:** `FR-12 / FR-15: Kiểm soát truy cập API Sản phẩm (Security / API)`
3. **Problem summary:** `Enforce Access Control: POST, PUT, DELETE /api/products lack authenticateToken middleware, allowing unauthenticated guests and regular users to manipulate products.`
4. **How to reproduce the defect:**
    - **Environment:** Backend API `http://localhost:3000/api/products`.
    - **Steps to Reproduce:**
        1. Mở terminal, gửi request `POST /api/products` tạo sản phẩm mới mà không gửi Header `Authorization`.
        2. Gửi request `DELETE /api/products/1` mà không gửi Header `Authorization`.
    - **Expected Behavior:** Backend từ chối với HTTP 401 Unauthorized (hoặc HTTP 403 Forbidden nếu là tài khoản User thường) theo đặc tả FR-12.
    - **Actual Behavior:** Cả hai request đều trả về HTTP 200 thành công, cho phép khách vãng lai tùy ý tạo và xóa sản phẩm trong CSDL.
    - **Root Cause & Code Reference:** Tại file `backend/server.js` dòng 173, 185, 197: các route định nghĩa là public `app.post("/api/products", (req, res) => ...)` thiếu middleware xác thực.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026

7. **Assign to:** Backend Developer / Security Engineer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)` — Lỗ hổng bảo mật cấp cao (OWASP Top 1: Broken Access Control).
10. **Severity:** `Fatal` — Cho phép bất kỳ ai can thiệp, xóa sạch hoặc chèn dữ liệu giả vào kho sản phẩm.

BUG-FR15-02: Giao diện Web Admin tự động đổi tên hàng loạt toàn bộ sản phẩm trên UI khi sửa một sản phẩm

1. **Bug ID:** `BUG-FR15-02`
2. **Function name:** `FR-15: Cập nhật sản phẩm trên Web Admin (Web Client UI)`
3. **Problem summary:** `Maintain Product Update Isolation: Editing a product causes all other products in the UI state to be erroneously renamed to the same name.`
4. **How to reproduce the defect:**
   - **Environment:** Web Admin `http://localhost:5174`, Chrome Browser.
   - **Steps to Reproduce:**
     1. Đăng nhập Admin, chuyển sang tab "Sản phẩm".
     2. Bấm "Sửa" tại sản phẩm đầu tiên (iPhone 15 Pro Max).
     3. Sửa tên thành `"iPhone 15 Pro Max Mới"`.
     4. Bấm "Lưu sản phẩm".
     5. Quan sát danh sách sản phẩm trong bảng bên dưới.
   - **Expected Behavior:** Chỉ sản phẩm ID 1 được đổi tên; các sản phẩm Samsung, Macbook, AirPods vẫn giữ nguyên tên cũ (theo đặc tả FR-15 dòng 198).
   - **Actual Behavior:** Toàn bộ 5 sản phẩm trong bảng đều bị đổi tên thành `"iPhone 15 Pro Max Mới"`.
   - **Root Cause & Code Reference:** Tại file `frontend-admin/src/App.jsx` dòng 110-114:

```
const fakeMassUpdatedProducts = products.map((p) => ({
  ...p,
  name: productForm.name,
}));
setProducts(fakeMassUpdatedProducts);
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Frontend Developer
8. **Status:** `Open / New`
9. **Priority:** `High`
10. **Severity:** `Serious` — Gây sai lệch nghiêm trọng hiển thị dữ liệu quản lý.

BUG-FR15-03: Backend không kiểm tra giá tiền, chấp nhận lưu giá bằng 0 và số âm vào CSDL

1. **Bug ID:** `BUG-FR15-03`
2. **Function name:** `FR-15: Validation giá sản phẩm (Backend API)`
3. **Problem summary:** `Validate Product Price: Backend accepts zero and negative prices instead of enforcing positive price constraint (> 0).`

4. **How to reproduce the defect:**
    - **Environment:** Backend API `:3000`.
    - **Steps to Reproduce:**
        1. Gửi request `POST /api/products` với body: `{"name": "Sản phẩm lỗi giá", "price": 0, "category_id": 1}`.
        2. Gửi request `POST /api/products` với body: `{"name": "Sản phẩm giá âm", "price": -50000, "category_id": 1}`.
    - **Expected Behavior:** Backend từ chối với HTTP 400 Bad Request kèm thông báo lỗi giá tiền phải là số dương > 0.
    - **Actual Behavior:** Cả hai sản phẩm đều được tạo thành công với HTTP 200 và lưu giá `0` và `-50000` vào CSDL SQLite.
    - **Root Cause:** Tuyến `POST /api/products` và `PUT /api/products/:id` thiếu validation `if (!price || price <= 0) return res.status(400)...`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)`
10. **Severity:** `Fatal` — Gây tổn hại tài chính khi bán hàng giá 0 ₫ hoặc số âm.

BUG-FR15-04: Backend không kiểm tra độ dài tên sản phẩm, chấp nhận tên rỗng và vượt quá 255 ký tự

1. **Bug ID:** `BUG-FR15-04`
2. **Function name:** `FR-15: Validation tên sản phẩm (Backend API)`
3. **Problem summary:** `Validate Product Name: Backend accepts empty names and names exceeding 255 characters without validation.`
4. **How to reproduce the defect:**
    - **Environment:** Backend API `:3000`.
    - **Steps to Reproduce:**
        1. Gửi `POST /api/products` với `name: ""`.
        2. Gửi `POST /api/products` với `name: "A" * 256` (chuỗi 256 ký tự).
    - **Expected Behavior:** Backend từ chối với HTTP 400 báo tên bắt buộc và không quá 255 ký tự.
    - **Actual Behavior:** Hệ thống tạo sản phẩm thành công với tên rỗng và tên 256 ký tự trong CSDL.
    - **Root Cause:** Backend thiếu kiểm tra `if (!name || name.trim().length === 0 || name.length > 255)`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `High`
10. **Severity:** `Serious` — Vi phạm đặc tả trường dữ liệu bắt buộc và độ dài tối đa.

BUG-FR15-05: Lỗ hổng SQL Injection nghiêm trọng tại API tìm kiếm sản phẩm GET /api/products?search=

1. **Bug ID:** `BUG-FR15-05`
2. **Function name:** `FR-05 / FR-15: Tìm kiếm sản phẩm (Security / API)`
3. **Problem summary:** `Prevent SQL Injection: Search endpoint concatenates raw user query into SQL string, exposing full database.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `http://localhost:3000/api/products?search=`.
   - **Steps to Reproduce:**
     1. Gửi request `GET http://localhost:3000/api/products?search=' OR '1'='1`.
     2. Quan sát kết quả JSON trả về.
   - **Expected Behavior:** Hệ thống xử lý chuỗi tìm kiếm an toàn dưới dạng tham số (parameterized query), không trả về các sản phẩm không khớp tên.
   - **Actual Behavior:** Toàn bộ danh sách sản phẩm trong CSDL bị dump ra ngoài do điều kiện `'1'='1` luôn đúng.
   - **Root Cause & Code Reference:** Tại file `backend/server.js` dòng 150:

```
const query = `SELECT * FROM products WHERE name LIKE
'%${searchQuery}%'`;
db.all(query, [], ...);
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)`
10. **Severity:** `Fatal` — Lỗ hổng bảo mật cấp độ cao (OWASP Top 3: Injection).

BUG-FR15-06: Backend không validate khóa ngoại danh mục, chấp nhận category_id không tồn tại

1. **Bug ID:** `BUG-FR15-06`
2. **Function name:** `FR-15: Toàn vẹn dữ liệu danh mục (Database Integrity)`
3. **Problem summary:** `Enforce Foreign Key Constraint: Backend accepts non-existent category_id (e.g. 9999), creating orphaned product records.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Gửi `POST /api/products` với body `{"name": "Sản phẩm mồ côi", "price": 500000, "category_id": 9999}`.
   - **Expected Behavior:** Backend kiểm tra danh mục tồn tại, từ chối với HTTP 400 Bad Request nếu không tìm thấy ID danh mục.
   - **Actual Behavior:** Sản phẩm được tạo thành công với `category_id: 9999` trong CSDL, gây lỗi khi client hiển thị danh mục theo sản phẩm.
   - **Root Cause:** CSDL SQLite không bật ràng buộc khóa ngoại và backend thiếu câu truy vấn kiểm tra `SELECT id FROM categories WHERE id = ?`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)

6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `Medium`
10. **Severity:** `Serious` — Gây phá vỡ tính toàn vẹn tham chiếu của CSDL.

BUG-FR15-07: Bất nhất kiểu dữ liệu trường price giữa sản phẩm ID chẵn (String) và ID lẻ (Number)

1. **Bug ID:** `BUG-FR15-07`
2. **Function name:** `FR-15: API Chi tiết sản phẩm GET /api/products/:id (API Data Type)`
3. **Problem summary:** `Ensure Type Consistency: Backend converts price to String on even IDs and leaves Number on odd IDs.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Gọi `GET /api/products/1` → Quan sát kiểu của `price` (kết quả: `30000000` - Number).
     2. Gọi `GET /api/products/2` → Quan sát kiểu của `price` (kết quả: `"28000000"` - String).
   - **Expected Behavior:** Trường `price` luôn luôn đồng nhất là kiểu dữ liệu số (`Number`).
   - **Actual Behavior:** Sản phẩm ID chẵn bị ép kiểu thành chuỗi `"28000000"`, gây lỗi tính toán số học trên ứng dụng client.
   - **Root Cause & Code Reference:** Tại file `backend/server.js` dòng 168:

     ```
     if (row.id % 2 === 0) row.price = row.price.toString();
     ```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Backend Developer
8. **Status:** `Open / New`
9. **Priority:** `Low`
10. **Severity:** `Medium` — Lỗi sai chuẩn hợp đồng dữ liệu API (API Schema Contract Violation).

PHẦN 4: DANH SÁCH LỖI PHÁT HIỆN TẠI FEATURE D — POOL D: MOBILE CART & CHECKOUT

> [!IMPORTANT] **Tuyên Bố Phương Pháp Luận & Tính Minh Bạch Môi Trường Thực Thi (Methodology & Scope Transparency):**
>
> - **Phương pháp kiểm thử:** Đối với phân hệ Mobile App (Pool D), Tester áp dụng phương pháp **Kiểm thử hộp trắng / Phân tích mã nguồn tĩnh (White-box Static Code Inspection)** trên toàn bộ file logic giao diện [`frontend-mobile/App.js`](file:///c:/Coding/SoftwareTesting/Seminar/src/eshop-sut/frontend-mobile/App.js) kết hợp **Kiểm thử tích hợp Backend API (Backend API Integration Testing)** trên máy chủ local (`http://localhost:3000`).

> - **Lý do kỹ thuật & Phạm vi:** Thư mục `frontend-mobile` của dự án SUT chưa cài đặt `node_modules` và không khởi chạy máy ảo giả lập Expo. Mã nguồn `App.js` thể hiện tường minh các đoạn mã lỗi được cài cắm có chủ đích (Deliberate Defect Injection) của SUT như: `parsed + 1` (dòng 620), `cart.slice(0, -1)` (dòng 391), hardcode IP LAN (dòng 16), và thiếu confirm dialog (dòng 155). Toàn bộ hành vi của giỏ hàng, cập nhật state React và payload gửi qua mạng được phân tích và chứng minh trực tiếp từ mã nguồn và dữ liệu thực tế tại Backend.

BUG-MOB-01: Giao diện Giỏ hàng tự động cộng thêm 1 khi người dùng chỉnh sửa số lượng

1. **Bug ID:** `BUG-MOB-01`
2. **Function name:** `FR-07: Cập nhật số lượng trong giỏ hàng (Mobile App UI)`
3. **Problem summary:** `Update Cart Quantity: Cart screen erroneously increments entered quantity by 1 (parsed + 1), making it impossible to set exact desired quantity.`
4. **How to reproduce the defect:**
   - **Environment:** React Native Expo App (White-box Static Code Inspection on App.js) & Backend API http://localhost:3000.
   - **Steps to Reproduce:**
     1. Thêm 1 sản phẩm vào giỏ hàng.
     2. Mở màn hình Giỏ hàng (`Giỏ`).
     3. Tại ô nhập số lượng, gõ số `2`.
     4. Quan sát giá trị hiển thị và thành tiền.
   - **Expected Behavior:** Số lượng cập nhật đúng bằng `2`, thành tiền bằng `đơn giá x 2`.
   - **Actual Behavior:** Số lượng bị ép thành `3` ($2 + 1$), thành tiền bị tính đội lên thành `đơn giá x 3`.
   - **Root Cause & Code Reference:** Tại file `frontend-mobile/App.js` dòng 618-621:

```
newCart[index].quantity =
  Number.isFinite(parsed) && parsed > 0
    ? parsed + 1 // Cố tình cộng thêm 1
    : 1;
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Mobile Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)` — Làm sai lệch số lượng đặt mua của người dùng.
10. **Severity:** `Serious`

BUG-MOB-02: Ứng dụng Mobile âm thầm vứt bỏ sản phẩm cuối cùng khỏi đơn hàng khi giỏ hàng có nhiều sản phẩm

1. **Bug ID:** `BUG-MOB-02`
2. **Function name:** `FR-08: Đặt hàng từ Giỏ hàng trên Mobile (Mobile Checkout Flow)`
3. **Problem summary:** `Submit Order Items: Mobile app drops the last cart item (cart.slice(0, -1)) when cart has multiple items while charging full total.`
4. **How to reproduce the defect:**

- **Environment:** React Native Expo App (White-box Static Code Inspection on App.js) & Backend API http://localhost:3000.
- **Steps to Reproduce:**
  1. Thêm 2 sản phẩm khác nhau vào giỏ (Ví dụ: iPhone 15 Pro Max 30tr và AirPods Pro 6tr). Tổng tiền: 36,000,000 ₫.
  2. Mở Giỏ hàng, bấm "Thanh toán".
  3. Bấm "Xác Nhận Đơn Hàng".
  4. Kiểm tra dữ liệu đơn hàng đã tạo trong lịch sử đơn hoặc CSDL bảng `orders`.
- **Expected Behavior:** Đơn hàng lưu trọn vẹn cả 2 sản phẩm.
- **Actual Behavior:** Khách hàng bị tính tiền trọn vẹn 36,000,000 ₫ nhưng payload gửi lên backend bị cắt mất sản phẩm AirPods Pro 2 do `cart.slice(0, -1)`. Khách trả tiền 2 món nhưng chỉ nhận 1 món!
- **Root Cause & Code Reference:** Tại file `frontend-mobile/App.js` dòng 391:

```
body: JSON.stringify({
  items: cart.length > 1 ? cart.slice(0, -1) : cart, // Cắt bỏ phần tử cuối!
  total_amount: finalAmount,
  coupon_id: couponResult?.coupon_id || null,
}),
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Mobile Developer
8. **Status:** `Open / New`
9. **Priority:** `Immediate (Critical)` — Lỗi gian lận nghiêm trọng làm thất thoát hàng hóa hoặc bớt xén quyền lợi người mua.
10. **Severity:** `Fatal`

BUG-MOB-03: Hardcode địa chỉ IP mạng nội bộ trong cấu hình API_URL

1. **Bug ID:** `BUG-MOB-03`
2. **Function name:** `Configuration: Cấu hình kết nối mạng (Mobile Network Config)`
3. **Problem summary:** `Configure API Endpoint: Mobile app hardcodes LAN private IP http://192.168.10.13:3000/api, breaking connectivity on other networks.`
4. **How to reproduce the defect:**
   - **Environment:** React Native Expo App (White-box Static Code Inspection on App.js).
   - **Steps to Reproduce:**
     1. Chạy ứng dụng mobile trên máy hoặc mạng Wi-Fi khác với dải mạng `192.168.10.x`.
     2. Mở ứng dụng.
   - **Expected Behavior:** Ứng dụng đọc cấu hình từ file `.env` hoặc cho phép cấu hình URL động, kết nối tới backend thành công.
   - **Actual Behavior:** Mọi API gọi ra ngoài đều bị lỗi Network Request Failed, ứng dụng không tải được sản phẩm.
   - **Root Cause & Code Reference:** Tại file `frontend-mobile/App.js` dòng 16:

```
const API_URL = "http://192.168.10.13:3000/api";
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Mobile Lead Developer
8. **Status:** `Open / New`
9. **Priority:** `High`
10. **Severity:** `Fatal` — Khiến ứng dụng tê liệt hoàn toàn khi triển khai ngoài mạng nội bộ của dev.

BUG-MOB-04: Thao tác xóa sản phẩm trong giỏ thiếu hoàn toàn hộp thoại xác nhận (Confirmation Dialog)

1. **Bug ID:** `BUG-MOB-04`
2. **Function name:** `FR-07: Xóa sản phẩm khỏi giỏ hàng (Mobile App UI)`
3. **Problem summary:** `Confirm Cart Deletion: Deleting an item immediately removes it without Alert confirmation, violating FR-07 line 97.`
4. **How to reproduce the defect:**
   - **Environment:** React Native Expo App (White-box Static Code Inspection on App.js).
   - **Steps to Reproduce:**
     1. Mở màn hình Giỏ hàng có sản phẩm.
     2. Nhấp chữ "Xóa" màu đỏ cạnh sản phẩm.
   - **Expected Behavior:** Xuất hiện Alert dialog hỏi "Bạn có chắc chắn muốn xóa sản phẩm này không?" với 2 lựa chọn [Hủy] và [Đồng ý] theo đặc tả FR-07 dòng 97.
   - **Actual Behavior:** Sản phẩm bị xóa ngay lập tức khỏi mảng `cart` mà không có bất kỳ bước xác nhận nào, gây nguy cơ bấm nhầm rất cao trên màn hình cảm ứng di động.
   - **Root Cause & Code Reference:** Tại file `frontend-mobile/App.js` dòng 155-159:

```
const removeFromCart = (index) => {
  const newCart = [...cart];
  newCart.splice(index, 1);
  setCart(newCart);
};
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Mobile Developer
8. **Status:** `Open / New`
9. **Priority:** `Medium`
10. **Severity:** `Medium`

BUG-MOB-05: Nhãn tổng tiền hiển thị sai quy chuẩn đặc tả ("Tổng tạm tính" thay vì "Tổng cộng")

1. **Bug ID:** `BUG-MOB-05`
2. **Function name:** `FR-07: Hiển thị tổng tiền giỏ hàng (Mobile App UI / Label)`
3. **Problem summary:** `Enforce Label Standard: Cart screen displays 'Tổng tạm tính' instead of required 'Tổng cộng' label.`
4. **How to reproduce the defect:**
   - **Environment:** React Native Expo App (White-box Static Code Inspection on App.js).
   - **Steps to Reproduce:**
     1. Mở Giỏ hàng có sản phẩm.
     2. Quan sát dòng hiển thị tổng tiền phía trên các nút bấm thao tác.
   - **Expected Behavior:** Nhãn hiển thị là `"Tổng cộng: ..."` theo đúng yêu cầu tại đặc tả FR-07 dòng 99.
   - **Actual Behavior:** Nhãn hiển thị là `"Tổng tạm tính: ..."`.
   - **Root Cause & Code Reference:** Tại file `frontend-mobile/App.js` dòng 637-639:

```
<Text style={styles.totalText}>
  Tổng tạm tính: {formatMoney(cartTotal)}
</Text>
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Mobile Developer
8. **Status:** `Open / New`
9. **Priority:** `Low`
10. **Severity:** `Cosmetic`

BUG-MOB-06: Giao diện Giỏ hàng mobile thiếu hoàn toàn các nút tăng/giảm (+/-) số lượng

1. **Bug ID:** `BUG-MOB-06`
2. **Function name:** `FR-07: Bộ điều khiển số lượng trên Mobile (Mobile UI / UX)`
3. **Problem summary:** `Provide Quantity Controls: Cart screen lacks +/- buttons, forcing manual virtual keyboard input.`
4. **How to reproduce the defect:**
   - **Environment:** React Native Expo App (White-box Static Code Inspection on App.js).
   - **Steps to Reproduce:**
     1. Mở Giỏ hàng có sản phẩm.
     2. Quan sát khu vực điều chỉnh số lượng của từng mặt hàng.
   - **Expected Behavior:** Có 2 nút bấm [+] và [-] đặt cạnh ô số lượng để người dùng chạm nhanh theo đặc tả FR-07 dòng 95.
   - **Actual Behavior:** Chỉ hiển thị 1 ô `TextInput` nhập chữ số, buộc người dùng phải kích hoạt bàn phím ảo di động và dính lỗi `BUG-MOB-01`.
   - **Root Cause & Code Reference:** Tại file `frontend-mobile/App.js` dòng 609-625 chỉ render thẻ `<TextInput style={styles.cartQuantityInput} ... />`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 20/10/2026
7. **Assign to:** Mobile Developer

8. **Status:** `Open / New`
9. **Priority:** `Medium`
10. **Severity:** `Medium`